

INFORME MERCURY: TENDENCIAS EN CUANTIFICACIÓN DE RIESGOS DE CIBERSEGURIDAD PARA ESPAÑA (2024-2025)

Resumen Ejecutivo

España enfrenta un escenario de ciberseguridad paradójico: posiciona entre los líderes europeos en marcos regulatorios y gobernanza estratégica (Tier 1 en el Índice Global de Ciberseguridad de la UIT 2024), pero gestiona casi 100.000 incidentes anuales con una tasa de crecimiento del 16,6% interanual. La amenaza ha escalado desde lo académico hacia lo operacional: organizaciones españolas necesitan metodologías cuantificables que traduzcan riesgos técnicos complejos en exposiciones financieras defensibles ante reguladores, aseguradores y directorios.

En este contexto, **Mercury Risk and Compliance, Inc.** —fundada en 2023 por pioneros en GRC y cuantificación de riesgos, con presencia verificada en Madrid desde 2021—propone un enfoque diferenciador: metodologías propietarias **AVRQ** (Advanced Asset Value-based Risk Quantification), **ACET** (Automated Controls Efficacy Testing) y **A.D.A.M.** (Automated Dynamic Asset Mapping), que pivotan desde la *mitigación de pérdidas* hacia la *protección y ampliación de valor de activos*.

Este informe examina: (1) la arquitectura conceptual de Mercury aplicada al contexto regulatorio español; (2) cómo Mercury se posiciona ante marcos competidores como FAIR (Factor Analysis of Information Risk) y CAsPeA; (3) indicadores territoriales y de cumplimiento NIS2 en España; y (4) recomendaciones para adopción estratégica en organizaciones críticas españolas.

1. MARCO DE CONTEXTO: CIBERSEGURIDAD EN ESPAÑA 2024-2025

1.1 Panorama de Amenazas y Incidentes

El Instituto Nacional de Ciberseguridad (INCIBE), entidad dependiente del Ministerio para la Transformación Digital, reportó en 2024 un total de **97.348 incidentes de ciberseguridad gestionados**, representando un incremento del 16,6% respecto a 2023. De este total, el 67,6% afectó a ciudadanía (65.808 casos) y el 32,4% a empresas, pymes y autónomos (31.540 casos).¹²

² <https://www.grupoaseguranza.com/noticias-de-seguros/incibe-gestiono-2024-16-6-mas-ciberincidentes-21-8-mas-consultas>

² <https://www.incibe.es/incibe/sala-de-prensa/incibe-presenta-su-balance-de-ciberseguridad-2024-con-mas-de-97000-incidentes>

² <https://www.incibe.es/incibe/sala-de-prensa/incibe-presenta-su-balance-de-ciberseguridad-2024-con-mas-de-97000-incidentes>

² <https://www.grupoaseguranza.com/noticias-de-seguros/incibe-gestiono-2024-16-6-mas-ciberincidentes-21-8-mas-consultas>

² <https://ack3.eu/spain-boosts-cybersecurity-billion-investment/>

-
- 2 <https://www.ituser.es/actualidad/2024/09/espana-obtiene-una-valoracion-casi-perfecta-en-el-global-cybersecurity-index-2024-de-itu>
 - 2 <https://springboard35.com/en/blog/cybersecurity-in-spain-challenges-opportunities/>
 - 2 <https://www.ituser.es/actualidad/2024/09/espana-obtiene-una-valoracion-casi-perfecta-en-el-global-cybersecurity-index-2024-de-itu>
 - 2 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>
 - 2 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>
 - 2 <https://sales.superagi.com/company/mercury-risk-and-compliance,-inc.>
 - 2 <https://www.datoscif.es/empresa/mercury-risk-compliance-solutions-sl>
 - 2 <https://sales.superagi.com/company/mercury-risk-and-compliance,-inc.>
 - 2 <https://mercuryrisk.com/>
 - 2 <https://mercuryrisk.com/>
 - 2 <https://mercuryrisk.com/>
 - 2 <https://aisel.aisnet.org/isd2014/proceedings2024/managingdevops/4/>
 - 2 <https://aisel.aisnet.org/cgi/viewcontent.cgi?article=1636\&context=isd2014>
 - 2 <https://www.balbix.com/insights/fair-model-for-risk-quantification-pros-and-cons/>
 - 2 <https://www.fairinstitute.org/blog/integrating-fair-models-a-unified-framework-for-cyber-risk-management>
 - 2 <https://www.centraleyes.com/decoding-the-cyber-risk-quantification-models/>
 - 2 <https://axio.com/insights/why-traditional-crq-falls-short-and-how-modern-solutions-fill-the-gaps/>
 - 2 <https://www.linkedin.com/pulse/cyber-risk-quantification-models-fair-vs-graace-bill-frank-rxmse>
 - 2 https://www.enisa.europa.eu/sites/default/files/2025-06/The EU Cybersecurity Index 2024_en_0.pdf
 - 2 https://www.enisa.europa.eu/sites/default/files/2025-06/The EU Cybersecurity Index 2024_en_0.pdf
 - 2 <https://www.mordorintelligence.com/industry-reports/spain-cybersecurity-market>
 - 2 <https://www.sourcesecurity.com/news/mercury-security-access-control-platform-launch-co-823-ga-co-9380-ga-co-12538-ga-co-1529393926-ga-co-6621-ga-npr.1743757208.html>
 - 2 <https://www.grupoaseguranza.com/noticias-de-seguros/incibe-gestiono-2024-16-6-mas-ciberincidentes-21-8-mas-consultas>
 - 2 <https://www.incibe.es/incibe/sala-de-prensa/incibe-presenta-su-balance-de-ciberseguridad-2024-con-mas-de-97000-incidentes>
 - 2 <https://www.mercury-security.com/category/insights/blog/>
 - 2 https://www.enisa.europa.eu/sites/default/files/2025-06/The EU Cybersecurity Index 2024_en_0.pdf
 - 2 <https://www.merqury.eu>
 - 2 https://administracionelectronica.gob.es/pae_Home/en/pae_OBSAE/Posicionamiento-Internacional/Summary-Spain-international-rankings/ITU-Global-Cybersecurity-Index-2024.html
 - 2 <https://www.itdigitalsecurity.es/actualidad/2024/09/espana-obtiene-una-valoracion-casi-perfecta-en-el-global-cybersecurity-index-2024-de-itu>
 - 2 <https://www.ituser.es/actualidad/2024/09/espana-obtiene-una-valoracion-casi-perfecta-en-el-global-cybersecurity-index-2024-de-itu>
 - 2 <https://www.youtube.com/watch?v=Slf6OFhtrGc>
 - 2 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>
 - 2 <https://www.mercury-security.com/resources/>
 - 2 <https://sales.superagi.com/company/mercury-risk-and-compliance,-inc.>
 - 2 <https://mercuryrisk.com/>
 - 2 <https://mercuryiss.com.au>
 - 2 <https://www.mordorintelligence.com/industry-reports/spain-cybersecurity-market>
 - 2 <https://www.mercury-security.com/2025-controller-trend-report/>

Vector de Ataque	Casos 2024	% del Total	Tendencia
Malware (incluyendo ransomware)	42.136	43,3%	Estable
Fraude online (phishing principal)	38.000+	43,2%	En aumento
Intrusiones no autorizadas	7.470	7,7%	Variable
Tiendas online fraudulentas	2.122	2,2%	Emergente
Total	97.348	100%	+16,6%

Entre operadores esenciales e importantes (alineados con NIS2), se registraron **341 incidentes**, con el 24,6% en transporte y 23,8% en sector financiero. Adicionalmente, INCIBE detectó y notificó **183.851 sistemas vulnerables relevantes** susceptibles de explotación.³⁴

1.2 Inversión Gubernamental y Posicionamiento Estratégico

En mayo de 2025, el Gobierno de España aprobó medidas para fortalecer ciberseguridad y defensa cibernética con un presupuesto sin precedentes de **€1.157 millones** como parte del Plan Nacional de Ciberseguridad. Este esfuerzo se articula con la Estrategia Industrial y Tecnológica de Seguridad y Defensa, consolidando a España como actor estratégico en defensa cibernética europea.⁵

² <https://industrialcyber.co/threats-attacks/enisa-publishes-technical-guidance-to-strengthen-nis2-cybersecurity-risk-management/>

² <https://www.twobirds.com/en/insights/2025/eu-cybersecurity--enisa-publishes-final-nis2-guidance>

² <https://www.enisa.europa.eu/publications/nis2-technical-implementation-guidance>

² <https://mercury.com/blog/identifying-and-measuring-startup-key-performance-indicators>

² <https://aisel.aisnet.org/cgi/viewcontent.cgi?article=1636&context=isd2014>

² <https://aisel.aisnet.org/isd2014/proceedings2024/managingdevops/4/>

² <https://mercuryt.com.au/cybersecurity/>

² <https://www.fairinstitute.org/blog/integrating-fair-models-a-unified-framework-for-cyber-risk-management>

² [https://1616664.fs1.hubspotusercontent-na1.net/hubfs/1616664/FAIR Institute -- Integrating FAIR Models for Cyber Risk Management \(December 2024\).pdf](https://1616664.fs1.hubspotusercontent-na1.net/hubfs/1616664/FAIR%20Institute%20--%20Integrating%20FAIR%20Models%20for%20Cyber%20Risk%20Management%20(December%202024).pdf)

² <https://www.mercury-security.com/2025-trends-in-access-controllers-report/>

² <https://springboard35.com/en/blog/cybersecurity-in-spain-challenges-opportunities/>

La asignación presupuestaria se distribuye como sigue:

- 60%: Ministerio de Defensa, incluyendo CCN-CERT e Mando Conjunto del Ciberespacio
- Porcentaje significativo: Expansión del Centro de Operaciones de Seguridad 5G (SOC 5G), auditorías automatizadas de servicios digitales públicos, sistemas de detección de amenazas potenciados por IA
- Fondos adicionales: €3.260 millones para modernización de sistemas de telecomunicaciones encriptados de Fuerzas Armadas y adquisición de satélites, antenas, radares.⁴

1.3 Posicionamiento en Índices Internacionales

Índice Global de Ciberseguridad de la UIT 2024: España alcanzó la clasificación **Tier 1 (Role-modelling)**, compartiendo este nivel con 19 países europeos adicionales, únicamente por debajo de Italia, Reino Unido y Turquía que lograron puntuación perfecta.⁶

El desempeño se desglosó así por pilares (máximo 20 puntos cada uno):

Pilar	Puntuación	Estado
Marco Legal	20/20	Excelente
Medidas Técnicas	20/20	Excelente
Medidas Organizacionales	20/20	Excelente
Desarrollo de Capacidades	19,74/20	Muy Bueno
Cooperación	20/20	Excelente

A pesar de este posicionamiento aparentemente robusto, expertos subrayan que estas puntuaciones reflejan "fuerza relativa" más que capacidad absoluta de protección. España enfrenta desafíos operacionales reales: únicamente el 52% de organizaciones españolas han adoptado marcos de seguridad avanzados, dejando el 48% con exposición a amenazas modernas.⁷⁸

1.4 Normativa NIS2 y Transposición Legislativa Española

La Directiva NIS2 (Directiva (UE) 2022/2555) establece medidas para lograr un nivel común elevado de ciberseguridad en la UE. En España, el proceso de transposición avanzó con la aprobación por el Consejo de Ministros en enero de 2025 del *Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad*, integrando tanto la NIS2 como la Directiva de Resiliencia de Entidades Críticas (CER).⁹

Cronograma esperado de implementación legislativa:

Hito	Fecha	Estado
Registro acelerado en Congreso y Senado	Febrero 2025	Completado
Audiencias parlamentarias y enmiendas	Q3 2025	En curso
Enactación y publicación en BOE	Q1 2026	Proyectado
Lanzamiento del CNCS y notificación obligatoria	H1 2026	Proyectado

Entidades Afectadas (clasificación dual):

- Entidades Esenciales (EE): ≥250 empleados o €50M de facturación (grandes utilities, hospitales, ministerios)
- Entidades Importantes (EI): ≥50 empleados o €10M de facturación (logística, manufactura medianos)
- Proveedores clave: Todas las entidades críticas de DNS, telecomunicaciones, cloud, sin consideración de tamaño

Régimen Sancionador NIS2 en España:

Categoría	Multa Máxima	Observaciones
Entidades Esenciales	€10M o 2% facturación global	Suspensión de certificaciones, publicación
Entidades Importantes	€7M o 1,4% facturación global	Penalizaciones periódicas por incumplimiento
Otros	€10K-€2M (escalonado)	Órdenes correctivas, amonestaciones

Adicionalmente, miembros de directorios son **personalmente responsables** de incumplimientos de gobernanza cibernética y deben aprobar formalmente estrategias cibernéticas internas.¹⁰

2. MERCURY RISK AND COMPLIANCE INC.: ARQUITECTURA METODOLÓGICA Y DIFERENCIACIÓN COMPETITIVA

2.1 Perfil Institucional y Presencia Territorial

Mercury Risk and Compliance, Inc. fue constituida en 2023 con sede en Austin, Texas, fundada por Gavin Anthony Grounds (CEO) —reconocido pensador global en gestión de riesgos con experiencia en tecnología, telecomunicaciones, ciberseguridad y servicios financieros— y Grace E. Beason (COO, Co-fundadora), con expertise en gobernanza, riesgos y ciberseguridad en entornos multipaís.¹¹

La empresa mantiene operaciones en geografías estratégicas: Estados Unidos (Nueva York, Nueva Jersey, Boston, California), Reino Unido, Europa, Asia Sudoriental y Australasia. En España específicamente, se registró **Mercury Risk & Compliance Solutions SL** en Madrid (C/ O'Donnel 10, 2º B, 28048) con constitución el 7 de junio de 2021 y capital social de €3.000. Aunque la presencia española actual es reducida, la incorporación anterior a la fundación de la matriz estadounidense sugiere una estrategia de preparación territorial.¹²¹³

2.2 Filosofía Fundacional: "Grounds' Rules" y Risk-as-Currency

Mercury diferencia su propuesta mediante el concepto "**Grounds' Rules**", centrado en *risk-as-currency* —tratando el riesgo no como una magnitud abstracta a minimizar, sino como un activo empresarial cuyo valor se **protege, amplía y optimiza**. Esta filosofía contrasta con los enfoques tradicionales de "loss avoidance" (mitigación de pérdidas) prevalentes en frameworks como FAIR.¹⁴

La misión explícita es: "**Protecting value through innovative methodologies and solutions**"—protección de valor, no solo evitación de pérdidas.¹⁵

2.3 Arquitectura Metodológica: AVRQ, ACET y A.D.A.M.

Mercury integra tres metodologías propietarias en un ecosistema coherente:

2.3.1 AVRQ (*Advanced Asset Value-based Risk Quantification*)

AVRQ es una metodología **patent-pending** de cuantificación de riesgos basada en valor de activos, diferenciándose de FAIR en que:

- Enfoque primario: Valor de activos y su protección, no magnitud de pérdidas potenciales
- Cuantificación empírica: Scoring numérico empírico gestionable en múltiples dominios de riesgo (Ciber, Tecnología, Terceros, Usuario, Daño del Mundo Físico)
- Orientación empresarial: Habilitación de decisiones operacionales y de inversión centradas en retorno sobre riesgo, no reducción de riesgo a costa de eficiencia operativa
- Escalabilidad: Automatable y escalable en contextos organizacionales complejos

2.3.2 ACET (*Automated Controls Efficacy Testing*)

ACET implementa pruebas automatizadas de eficacia de controles, integrando inversiones ya realizadas en tecnologías GRC, ciberseguridad y auditoría existentes.¹⁶

Sus funcionalidades incluyen:

- Aprovechamiento de stacks tecnológicos preexistentes (SIEM, GRC, sistemas de auditoría)
- Evaluación continua, no periódica, de eficacia de controles
- Integración de datos cuantitativos en tiempo real para refinamiento de cuantificaciones de riesgo
- Reporte ejecutivo traducido a lenguaje de negocio (financiero, impacto operativo)

2.3.3 A.D.A.M. (*Automated Dynamic Asset Mapping*)

A.D.A.M. es una solución de machine learning que mapea dinámicamente activos en entornos organizacionales complejos, soportando identificación continua de:

- Activos críticos y su evolución
- Conexiones de dependencia entre activos (attack paths)
- Clasificación de riesgo granular
- Adaptación a cambios operacionales y amenazas emergentes

Esta capacidad es especialmente relevante en contextos españoles donde infraestructuras críticas (energía, transporte, sanidad) evolucionan constantemente bajo presión de digitalización y conformidad NIS2.

2.4 Diferenciación frente a FAIR (Factor Analysis of Information Risk)

Dimensión	FAIR	Mercury AVRQ
Enfoque primario	Severidad de vulnerabilidad y magnitud de pérdida esperada	Protección y ampliación de valor de activos
Cuantificación	Loss Event Frequency (LEF) + Loss Magnitude (LM) = ALE	Scoring empírico de valor de activos + riesgo
Fórmula base	$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$	Value-based assessment tailored to assets
Complejidad técnica	Alta (requiere expertise estadístico, distribuciones de probabilidad)	Media-alta (ML, ABC, mapeo dinámico)
Automatización	Limitada; requiere input manual periódico	Elevada; integración continua de datos
Orientación ejecutiva	Loss exposure en dólares; justificación defensiva	Return on Risk; decisiones de inversión ofensivas
Aplicabilidad multidominio	Principalmente cibernético	Ciber, Tecnología, Terceros, Usuario, Físico
Adopción internacional	Amplia (Open Group, estándar reconocido)	Emergente; posicionamiento en empresas de alto valor
Fortaleza pedagógica	Modelos mentales transferibles; transparencia metodológica	Automatización; velocidad de decisión
Debilidad crítica	"Black box" de distribuciones complejas; subjetividad en inputs	Confianza en datasets históricos; riesgo de sesgos ML

3. COMPARATIVE LANDSCAPE: MERCADO DE CUANTIFICACIÓN DE RIESGOS EN ESPAÑA Y EUROPA

3.1 CAsPeA: Competidor Académico Emergente

CAsPeA (Cost Assessment of Personnel Activities in Security) representa el enfoque académico-europeo más desarrollado para estimación de costes de ciberseguridad, estructurado explícitamente sobre **ISO/IEC 27001** y Activity-Based Costing (ABC).¹⁷¹⁸

Características de CAsPeA:

- Estándar de referencia: ISO/IEC 27001 directamente integrado
- Alcance: Estimación de costes de actividades de personal en gestión de ciberseguridad (diseño de políticas, capacitación, despliegue de medidas técnicas, testing)
- Exclusión deliberada: Externaliza costes de "cyberassets" (hardware, software, equipamiento físico)
- Herramienta: Spreadsheet calculable, facilitando adopción por pequeñas empresas
- Fortaleza: Universalidad, alineamiento con ISO, reproducibilidad
- Debilidad: Enfoque estrecho (solo personal); no integra cuantificación de riesgo o retorno sobre inversión

Aplicabilidad en España: CAsPeA se utiliza en contextos académicos (Universidades Politécnica de Gdańsk, Plymouth), pero su adopción empresarial en España es limitada. Su enfoque en costes de personal—no en riesgos críticos—lo sitúa como complemento, no sustituto, de frameworks como Mercury AVRQ.

3.2 FAIR Institucionalizado en Contexto Europeo

FAIR (Factor Analysis of Information Risk), desarrollado en 2005 por Jack Jones (ex-CISO de Nationwide Mutual Insurance, ahora presidente del FAIR Institute no-profit), se ha convertido en el **estándar abierto más ampliamente adoptado en Europa** para cuantificación cuantitativa de riesgos cibernéticos.¹⁹²⁰²¹

Puntos de adopción FAIR en contexto europeo/español:

- Empresas financieras españolas: Adopción creciente bajo presión de supervisores bancarios (Banco de España, EBA) para expresar riesgos en términos monetarios
- Seguros cibernéticos: Aseguradores españoles requieren cada vez más cuantificaciones FAIR para pricing y underwriting
- Consultorías Big Four: Presencia significativa de FAIR en metodologías de consultoría internacional operando en España
- Marcos de validación: FAIR complementa ISO 27005, COBIT, NIST CSF

Debilidades de FAIR documentadas en literatura académica contemporánea:22

1. Complejidad extrema: Algoritmos "black-box" con distribuciones probabilísticas sofisticadas requieren expertise estadístico que muchas organizaciones españolas carecen
2. Rigidez metodológica: Dificil adaptación a amenazas emergentes (IA, quantum, ataques supply-chain) sin reformulaciones significativas
3. Subjetividad disfrazada: Inputs de "expert opinion" sobre frecuencia de amenaza, capacidad de atacante, y magnitud de impacto introducen sesgos no abordados sistemáticamente
4. Enfoque defensivo: Orientación a "¿cuánto podemos perder?" vs. "¿cómo podemos ganar resiliencia?"

3.3 GRAACE y Modelos Emergentes

GRAACE (por sus componentes probabilísticas Granular Risk, Attack surfaces, Aggregate Control Effectiveness) emerge como framework alternativo que busca simplificar FAIR mientras mejora realismo:23

- Factorización explícita de superficies de ataque y caminos de ataque (attack paths)
- Curves de Excedencia de Pérdida que comunican rango completo de pérdidas probabilísticas
- Evita complicaciones de FAIR sobre "Primary Losses" vs. "Secondary Risk"

A la fecha, GRAACE carece de adopción institucional significativa en España, pero académicos españoles monitorean su evolución como alternativa estructurada a FAIR.

4. INDICADORES DE CIBERSEGURIDAD: TERRITORIAL Y REGULATORIO

4.1 Índice de Ciberseguridad UE 2024 (ENISA): Desagregación de Áreas

ENISA publicó en junio 2024 el **EU-Cybersecurity Index 2024**, herramienta de medición compuesta con estructura jerárquica que evalúa madurez de ciberseguridad en 27 Estados miembros UE.24

Puntuación general UE: 62,65/100 (out of 100)

Los Estados miembros muestran alineación considerable alrededor del promedio europeo (desviación promedio de 3,76 unidades). España, aunque no desagregada públicamente en el documento base, se sitúa en rango comparativamente alto dado su posicionamiento ITU Tier 1.25

Cuatro áreas temáticas del EU-CSI 2024:

Área	Puntuación UE	Descripción	Observación Crítica
Capacidad	64,51	Habilidad de sociedad para reconocer amenazas y prevenir incidentes	Majority de MS dentro rango 10-puntos del promedio
Operaciones	57,63	Habilidad de MS para conducir operaciones de ciberseguridad y asegurar resiliencia	Más baja de todas las áreas; brecha significativa
Mercado/Industria	62,36	Capacidad del sector privado para prevenir, detectar, analizar amenazas	Máxima alineación entre MS (desv. avg 2,78)
Política	66,09	Estado de desarrollo e implementación de política ciberseguridad	Puntuación más alta pero mínima alineación (variabilidad 27,28 a +17,45)

Indicadores con peores resultados europeos (foco de mejora):

5. Uso de IA en seguridad TIC por empresas: 3,18/100 (crítico)
6. Inversión en ciberseguridad por entidades esenciales/importantes: 7,14/100 (grave)
7. Certificación CSIRT: 10,31/100 (urgente)
8. Evaluación de riesgo cibernético por empresas: 32,01/100 (significativo)

España, como signataria NIS2, debe abordar específicamente estas brechas mediante reglamentación nacional (CNCS) y programas de concienciación.

4.2 Sectores Estratégicos Españoles: Exposición y Requisitos NIS2

La transposición española de NIS2 expande significativamente el perímetro de entidades sujetas a regulación. Sectores clave identificados:

Sector	Ejemplos	Incidentes 2024 (INCIBE)	Requisito NIS2
Energía \& Utilities	Hidroeléctrica, gasistas, distribuidoras	No desagregado	EE (≥ 250 emp)
Transporte	Aeropuertos, ferrocarril, logística	24,6% de 341 (83)	EE (mayoría), EI
Finanzas \& Tributario	Bancos, cajas, fintechs	23,8% de 341 (81)	EE (mayoría)
Sanidad	Hospitales ≈ 800 , clínicas	Creciente (ransomware)	EE (mayoría)
Telecomunicaciones	Movistar, Vodafone, Orange	Fundamental	EE (todas)
Infraestructura Digital	Cloud, DNS, CDN, data centers	Crítica	EE (todas)
Administración Pública	Ministerios, administraciones autonómicas, municipios grandes	19% de incidentes ENISA	EE/EI (escalonado)

Implicaciones Mercury para sectores españoles:

- Energía \& Transporte: AVRQ idóneo para mapear criticidad de activos OT/IT híbridos; ACET para validación continua
- Finanzas: AVRQ alinea con requisitos de supervisores (Banco España, CNMV) para cuantificación monetaria
- Sanidad: A.D.A.M. crítico para hospitales con redes complejas; AVRQ para scoring de equipamiento médico

4.3 Mercado Español de Ciberseguridad: Proyecciones de Inversión

El mercado de ciberseguridad en España alcanzó aproximadamente **USD 5,01 mil millones en 2026** y se proyecta crecer a **USD 7,91 mil millones en 2031**, con una CAGR de **9,54%**.²⁶

Desglose por segmento 2025-2026:

Segmento	% Revenue	CAGR 2025-2031	Observación
Solutions	69,12%	8,7%	Firewalls, EDR, IAM, application security
Cloud deployments	62,18%	13,12%	Mandatos CorA, conformidad ENS "Alto"
Managed Services	--	12,33%	Crecimiento más rápido; shortage de talento
Large Enterprises	59,10%	6,8%	Presupuestos profundos, riesgo complejo
SMEs	--	10,85%	Aceleración significativa; subvenciones Digital Spain

Verticales clave con mayor gasto:

9. BFSI (28,35% de revenue): Requerimientos PSD2, zero-trust
10. Healthcare (CAGR 15,85%): Digitalización de registros médicos, tele-consulta
11. Energía: OT-security tras aumento 43% en ataques
12. Manufactura \& Industrial: Integración IIoT requiere seguridad en edge

Implicación para Mercury: Expansión de mercado crea oportunidad para metodologías diferenciadas de cuantificación que no requieren expertise estadístico extremo (fortaleza relativa de AVRQ vs. FAIR).

5. APLICACIÓN ESTRATÉGICA DE MERCURY EN CONTEXTO ESPAÑOL: RECOMENDACIONES E IMPLEMENTACIÓN

5.1 Sectores Prioritarios para Adopción Mercury AVRQ

Basándose en análisis de criticidad de infraestructura, densidad de incidentes, y requisitos regulatorios NIS2, los siguientes sectores españoles son candidatos prioritarios para adopción de Mercury:

5.1.1 Infraestructura Crítica Digital

Requisito regulatorio: Todas las entidades son EE (Essential Entities) bajo NIS2

Justificación técnica: A.D.A.M. esencial para mapeo continuo de dependencias en entornos cloud, DNS, CDN

Caso de uso específico:

- Proveedor de cloud Spanish (ej., Telefónica Cloud, Orange Cloud)
- Desafío: 4.000+ alertas diarias requieren automatización de scoring de riesgo
- Solución Mercury: AVRQ + ACET automatiza priorización; CNCS reporta en <24h

5.1.2 Sistema Financiero Español

Requisito regulatorio: Banco de España (BdE), CNMV requieren cuantificación monetaria de riesgos

Justificación técnica: AVRQ traduce riesgos cibernéticos en impacto sobre valor de activos bancarios (depósitos, sistemas de pago)

Caso de uso específico:

- Banco español de talla mediano (ej., 1.000-5.000 empleados)
- Desafío: Sanciones PSD2, DORA exigen cuantificación precisa de riesgo operativo cibernético
- Solución Mercury: Integración con sistemas de pagos; AVRQ cuantifica riesgo de disruption; reporta a dirección en términos de impacto sobre ROA (Return on Assets)

5.1.3 Administración Pública Central y Autonómica

Requisito regulatorio: NIS2 requiere EE en ministeri large, administraciones autonómicas >50 empleados

Justificación técnica: ACET automatiza auditoría continua de controles (requería trimestral pre-NIS2); A.D.A.M. mapea complejidad de redes gubernamentales

Caso de uso específico:

- Ministerio o administración autonómica (ej., Consejería de Salud, Educación)
- Desafío: Auditorías manuales insuficientes; presupuestos crecientes pero eficiencia cuestionable
- Solución Mercury: ACET proporciona métricas continuas; AVRQ justifica inversiones ante Tribunal de Cuentas

5.1.4 Sanitario (Hospitales y Servicios de Salud)

Requisito regulatorio: ~800 hospitales públicos/privados talla mediana-grande son EE bajo NIS2

Justificación técnica: Equipamiento médico (imagenología, monitoreo paciente) + registros digitales requieren protección granular; AVRQ integra valor de atención al paciente, no solo daño financiero

Caso de uso específico:

- Hospital universitario español (ej., Complejo Hospitalario La Paz, Gregorio Marañón)
- Desafío: Ransomware causa pérdida de servicios críticos; reguladores requieren cuantificación de riesgo a vidas/pacientes
- Solución Mercury: AVRQ extiende scoring a impacto en calidad de atención; A.D.A.M. mapea dependencias OT/IT; ACET valida mitigaciones quirúrgicamente

5.2 Alineación Mercury con Requisitos NIS2 Españoles

El Centro Nacional de Ciberseguridad (CNCS), establecido en la Ley de Coordinación y Gobernanza de Ciberseguridad española, requerirá a entidades esenciales/importantes demostrar conformidad con medidas técnicas y organizativas específicas. Mercury alinea con estas exigencias como sigue:

Requisito NIS2	Medida NIS2	Control Mercury
Risk Management Framework	Identificación y documentación de riesgos	AVRQ + A.D.A.M.
Risk Assessment	Evaluación y priorización de riesgos	AVRQ scoring empírico
Risk Treatment Plan	Implementación de medidas de mitigación	ACET validación continua
Asset Classification	Clasificación de activos por criticidad	A.D.A.M. mapping dinámico
Access Control	Autenticación, autorización	ACET testing eficacia
Incident Response	Protocolo <24h de notificación	Mercury reportería automatizada
Board Reporting	Comunicación a órganos de dirección	AVRQ en lenguaje financiero/ejecutivo
Third-Party Risk	Evaluación de proveedores críticos	AVRQ extensión multidominio

5.3 Modelo de Implementación: Fases y Cronograma

Fase 1 (Meses 1-3): Assessment y Design

- Mapeo de activos críticos (A.D.A.M. fase exploratoria)
- Definición de "valor de activo" específico a contexto (financiero, operativo, reputacional)
- Capacitación de equipo central (3-5 personas)
- Presupuesto indicativo: €50-100K

Fase 2 (Meses 4-6): Implementación AVRQ Pilot

- Aplicación AVRQ a 3-5 escenarios de riesgo de alta prioridad
- Validación mediante datos históricos (incidentes previos, threat intelligence)
- Generación de reportes ejecutivos
- Presupuesto: €80-150K (licencias + consultoría)

Fase 3 (Meses 7-12): Integración ACET y Automatización

- Despliegue de ACET en tecnologías existentes (SIEM, GRC tools)
- Automatización de scoring continuo
- Integración con workflow de governance (board meetings trimestrales)
- Presupuesto: €150-250K (implementación + integración)

Fase 4 (Año 2): A.D.A.M. y Multidominio

- Expansión de Mercury a riesgos no-cibernéticos (Tecnología, Terceros, Usuario)
- Mapeo dinámico de supply chain crítica
- Optimización de ROI sobre inversiones de mitigación
- Presupuesto: €200-400K/año

Presupuesto total para pequeña-mediana empresa española (3-5 años): €480K-900K, representando <2% de presupuesto de ciberseguridad típico para entidad EE.

6. LIMITACIONES, RIESGOS Y CONSIDERACIONES CRÍTICAS

6.1 Madurez del Mercado y Confianza Institucional

Mercury Risk and Compliance Inc. fue constituida hace solo 2 años (2023). A pesar de que sus fundadores tienen trayectorias destacadas, la ausencia de track record de décadas (como FAIR Institute desde 2005) implica:

- Riesgo de continuidad: Empresa emergente podría pivotar o desaparecer
- Validación académica limitada: No existen publicaciones peer-reviewed extensas sobre AVRQ, ACET, A.D.A.M. en journals de impacto
- Adopción institucional: Ningún organismo regulador español (CNCS, INCIBE) ha emitido guidance sobre Mercury

Mitigación recomendada: Grandes organizaciones deberían condicionar adopción a acuerdos de código abierto o escrow de propiedad intelectual; adoptar Mercury como complemento, no sustituto, de frameworks standardizados (ISO 27005, NIST CSF).

6.2 Dependencia en Calidad de Datos y Riesgo de Sesgo ML

A.D.A.M. utiliza machine learning para mapeo dinámico. ML es vulnerable a:

- Datos históricos sesgados: Si entrenamiento se basó en incidentes de sectores específicos (ej., tecnología USA), A.D.A.M. puede subrepresentar riesgos únicos de contextos españoles (regulación AEPD, geografía de ataque lusa)
- Distribución de amenazas cambiante: Amenazas disruptivas (ej., ataques de IA generativa) podrían no estar bien representadas en datasets de entrenamiento

Recomendación: Implementaciones españolas de Mercury deben incluir equipo independiente de "red teaming" que valide outputs de A.D.A.M. contra escenarios específicos nacionales.

6.3 Integración con Ecosistema de Herramientas Español

ACET depende de integración con sistemas existentes (SIEM, GRC, auditoría). Ecosistema español altamente fragmentado:

- Large enterprises: Típicamente SAP, Salesforce, sistemas legacy en SAP-ERP o sistemas propios
- Administración pública: Proliferación de sistemas desconectados; migración a cloud lenta
- SMEs: Presupuesto tecnológico limitado; a menudo carecen de SIEM o GRC formales

Implicación: Costo de integración ACET podría ser significativamente mayor en contexto español que en USA. Mercury debería proporcionar "adaptadores" pre-construidos para plataformas comunes españolas (SUSE, OpenStack, sistemas públicos españoles).

7. CONCLUSIONES Y RECOMENDACIONES EJECUTIVAS

7.1 Posicionamiento de Mercury en Ciberseguridad Española

Mercury Risk and Compliance propone un enfoque diferenciador fundamentalmente valioso para contexto español:

13. Orientación a valor (no solo pérdida) resuena con cultura empresarial española que valora retorno sobre inversión y eficiencia operativa
14. Automatización (ACET, A.D.A.M.) aborda escasez crítica de talento cibernético en España (60% SMEs carecen de personal dedicado)
15. Multidominio extiende relevancia más allá de cibernética hacia riesgos tecnológicos, de terceros, y operacionales

Sin embargo, **Mercury no es panacea**: FAIR, CAsPeA, y otras metodologías retienen fortalezas en educación, estandarización y adopción institucional.

7.2 Recomendaciones por Perfil Organizacional

Para Grandes Empresas Españolas (Bancos, Telcos, Energía):

- Adoptar Mercury como complemento a FAIR, no sustituto
- Pilotar AVRQ en 2-3 dominios de riesgo de mayor criticidad
- Vincular salarios ejecutivos a retorno-sobre-riesgo (métrica Mercury)
- Timeline: 18-24 meses para full implementation

Para Administración Pública y Sectores Regulados:

- Exigir a Mercury conformidad explícita con directrices CNCS/INCIBE antes de adopción
- Utilizar Mercury como herramienta de auditoría continua (ACET) para cumplir NIS2
- Requiere validación de A.D.A.M. contra amenazas específicas de contexto público español
- Timeline: 24-36 meses; requiere aprobación de supervisores

Para SMEs Españolas:

- Mercury probablemente demasiado costoso como solución stand-alone
- Oportunidad: Proveedores de servicios gestionados (MSP, MSSP) españoles podrían ofertar "Mercury-as-a-Service" bundleado
- Timeline: Esperar adoptores grandes; aprender de their deployments

7.3 Necesidad de Investigación Adicional

Aún subsisten brechas de conocimiento:

16. Validación empírica de AVRQ: Se requieren publicaciones académicas peer-reviewed comparando AVRQ vs. FAIR en datasets españoles
17. Guidance regulatorio CNCS: Centro Nacional de Ciberseguridad debería emitir guidance sobre frameworks cuantificación aceptables (análogo a ENISA guidance para NIS2)
18. Benchmarking sectorial: Estudios de adopción en hospitales, bancos, administración pública españoles
19. Integración con estándares ISO: Mapeo explícito entre AVRQ y revisado ISO 27005:2022

8. REFERENCIAS Y FUENTES

INCIBE (2025). Balance de Ciberseguridad 2024. <https://www.incibe.es272829>

ENISA (2025). EU-Cybersecurity Index 2024.

[https://www.enisa.europa.eu/sites/default/files/2025-06/The EU Cybersecurity Index 2024_en_0.pdf3031](https://www.enisa.europa.eu/sites/default/files/2025-06/The%20EU%20Cybersecurity%20Index%2024_en_0.pdf3031)

ITU (2024). Global Cybersecurity Index 2024. <https://www.itu.int32333435>

Government of Spain (2025). Anteproyecto de Ley de Coordinación y Gobernanza de Ciberseguridad. Ministry of Interior3637

Mercury Risk and Compliance, Inc. (2024). Corporate Profile. <https://mercuryrisk.com383940>

Mordor Intelligence (2026). Cybersecurity Market in Spain. Market Research Report4142

ENISA (2025). Technical Implementation Guidance on NIS2 Cybersecurity Risk Management Measures. <https://www.enisa.europa.eu/publications/nis2-technical-implementation-guidance43444546>

Leszczyna, R., et al. (2024). ISO/IEC 27001-Based Estimation of Cybersecurity Costs with CAsPeA. In Proceedings of ISD 2024.474849

FAIR Institute. (2025). A FAIR Framework for Effective Cyber Risk Management. White Paper505152

Springboard35 (2025). Cybersecurity in Spain: Challenges and Opportunities.
<https://springboard35.com5354>

[Adicionales-150 como referencias cruzadas en análisis técnico]

Fecha: Enero 2026

Clasificación: Información Pública / Restringida a Ejecutivos

Próxima Revisión: Q2 2026 (post-aprobación CNCS de directrices NIS2 españolas)

3637383940414243444546474849505152535455565758596061626364656667686970717273
74757677787980818283848586878889909192
